AI Grid: AI Security Industry Direction, Enterprise AI Challenges, and a 1-Year and 3-Year Product Strategy

AI Grid should present itself as an independent **AI exposure management system of record**. Its job would be to discover every AI asset and agent across clouds, code, SaaS and endpoints. It would link each one to the identities, tools and data it can reach, score exposure conservatively, and produce regulator-grade evidence. It should connect to the runtime guardrails, gateways and identity providers that incumbents now own, not compete with them. The 1-year plan takes AI Grid from a demo prototype to 1–3 production design partners on an enterprise-grade, single-tenant-capable platform. The 3-year plan extends it into agent runtime governance and continuous assurance for multi-agent estates.

TL;DR

- **Market direction:** Securing AI is now a funded, fast-consolidating category. Gartner's August 26, 2026 forecast puts spend at $2.835B in 2026, rising 68.7% to $4.783B in 2027. Most specialist AI-security startups of 2023–2025 have been acquired by platform vendors. The white space left for a standalone product is neutral, cross-platform discovery plus an exposure graph linking agents, identities, tools and data, backed by evidence. Gateways and firewalls are not that space; incumbents already own them.
- **Year 1 (Q4 2026–Q3 2027):** Turn the demo into a product enterprises can buy and operate.
  - Production-grade discovery connectors for GitHub, AWS, Azure (re-enabled), GCP, Microsoft 365/Copilot Studio and MCP/IDE configurations.
  - An AI-native inventory and exposure graph.
  - Enterprise basics: SSO/SCIM, RBAC, audit, single-tenant/VPC deployment, SOC 2 Type I→II.
  - Integrations with SIEM, ITSM, GRC and IdP.
  - An evidence pack mapped to OWASP Agentic Top 10, MITRE ATLAS, NIST AI RMF, ISO/IEC 42001 and the EU AI Act.
  - Exit criteria: at least one paying production customer, at least two referenceable design partners, and zero Sev-1 security incidents in the product.
- **Years 2–3 (Q4 2027–Q3 2029):** Move from seeing agents to governing them.
  - Agent identity and delegated-authority graphing on top of Entra Agent ID, Okta, Google Agent Identity and the IETF/MCP authorization standards.
  - Runtime telemetry ingestion and behavioural baselines, kept separate from the conservative exposure score.
  - Continuous agent assurance testing.
  - Multi-agent (A2A) governance.
  - Policy-as-code enforcement delivered through partner enforcement points.

- Target: a category-defining position for AI exposure management in regulated enterprises.

Sources and Scope Note

The six attached AI Grid documents (architecture, backend, business logic, database, frontend, CLAUDE.md) and the attached enterprise strategy PDF could not be machine-read in this research session. Two consequences follow:

- The current-state assessment is based on the documented prior context from earlier work with the product team. Before this roadmap is baselined, it should be checked line by line against the attached documents; any conflict resolves in favour of the documents.
- The enterprise demand signals are generalised into patterns typical of large-enterprise five-year AI strategies and corroborated with industry data. They are cited as "Enterprise AI strategy reference (attached)" only where the theme is generic, and no identifying specifics are reproduced.

All industry claims come from web research current to September 2026.

Key Findings

1. **Spend is real, but sits in four segments with different competitive dynamics.**
   - Gartner forecasts the securing-AI market at $2,835M in 2026 and $4,783M in 2027 (+68.7%), and almost $7.7B by 2028. (gartner)
   - AI application security is the largest segment ($508M → $851M). (gartner)
   - AI usage control grows fastest (+73% in 2027, to $749M). AI gateways come next, growing from $251M in 2026 to $429M in 2027 (+70.9%), per Gartner's August 2026 forecast.
   - Gartner expects major vendors to keep leading in governance platforms and gateways, which build on existing enterprise systems. AI application security and usage control are where startups are entering. Gartner analyst Shailendra Upadhyay expects "increased consolidation and acquisitions, with larger cybersecurity companies buying these startups to broaden their offerings."
   - **Implication:** AI Grid's wedge should sit in AI application security and posture/exposure, not gateways.
2. **Access control and prompt injection are the dominant attack paths on agents.**
   - Gartner predicts that by 2029 over half of successful cyberattacks on AI agents will exploit access-control weaknesses and prompt injection. (gartner)
   - IBM's 2026 Cost of a Data Breach Report points the same way. It was produced with Ponemon, released July 29, 2026, and covers 602 breached organisations, with a record $4.99M global average breach cost. Its findings:
     - shadow AI rose to 43%, from 20%. Outlets differ on whether this is 43% of breached organisations or 43% of AI-related incidents;

        - incidents involving an organisation's own AI models or applications rose from 13% to 21%;
        - 92% of organisations with an AI-related incident lacked proper AI access controls. Kiteworks
    - This confirms that the identity-to-agent-to-data exposure graph is the right core asset.
3. **Consolidation has removed most of the independent field.**
    - Specialist AI-security vendors acquired since 2025 include Lakera (Check Point), Prompt Security (SentinelOne), SPLX (Zscaler), Pangea (CrowdStrike), Aim (Cato), CalypsoAI (F5), Apex (Tenable), Acuvity (Proofpoint), Astrix and Galileo (Cisco), TrojAI (A10), LayerX (Akamai) and Apono (1Password). Calcali Tech +6
    - Platform-scale deals closed: Google–Wiz ($32B, March 2026), Palo Alto Networks–CyberArk (~$25B, February 2026), and ServiceNow–Armis and ServiceNow–Veza. Feinternational
    - The funded independents left are Zenity ($125M Series C led by Norwest, August 3, 2026), HiddenLayer ($100M Series B, September 2026), Noma ($100M Series B, 2025) and Straiker ($64M, June 2026). Their pitch is independence.
4. **Platforms now ship "good-enough" agent governance inside their own ecosystems.**
    - Microsoft Entra Agent ID and Agent 365 reached general availability in spring 2026. Agent 365 is licensed per user and included in Microsoft 365 E7. Microsoft Learn +2
    - Google shipped Agent Identity, Agent Gateway and Model Armor. Medium Wiz launched an AI Application Protection Platform and AI-BOM covering AgentCore, Copilot Studio, Agentforce and Databricks. Tamnoon
    - ServiceNow AI Control Tower now discovers AI assets across the estate, adds Veza's access graph, and demos agent kill switches. The Register
    - **Implication:** AI Grid wins only where it is neutral across these estates and deeper on exposure and evidence than any single platform.
5. **Standards have converged enough to build on.**
    - OWASP Top 10 for Agentic Applications (ASI01–ASI10, December 2025). Cycode
    - MITRE ATLAS agentic techniques (e.g., AML.T0104 Publish Poisoned AI Agent Tool). DEV Community
    - NIST Cyber AI Profile (IR 8596 preliminary draft) and SP 800-53 overlays (COSAiS). arxiv Lab Space
    - ETSI EN 304 223 (13 principles across 5 lifecycle phases). ETSI
    - Singapore's Model AI Governance Framework for Agentic AI.

- MCP 2026-07-28, which is stateless and OAuth 2.1-aligned, plus the stable Enterprise-Managed Authorization extension. (modelcontextprotocol) (WorkOS)
- Agent identity work is still draft: IETF (`draft-ietf-wimse-aims-00`), NIST NCCoE concept paper. (nist) (ietf) Build on it through abstraction layers, not hard dependencies.

6. **Regulation bought time, not relief.**
   - The EU Digital Omnibus on AI (Regulation (EU) 2026/1744, in force 27 July 2026) defers Annex III high-risk obligations to 2 December 2027 and Annex I to 2 August 2028. (Usercentrics) (Lab Space)
   - GPAI and Article 50 transparency duties still apply. (Usercentrics) (VerifyWise)
   - Colorado replaced its AI Act with a narrower disclosure-focused law effective 1 January 2027. (Seyfarth Shaw LLP) (SecureW2)
   - Inventory and classification remain the prerequisite for compliance. (VerifyWise) That matches AI Grid's discovery-first principle and gives regulated enterprises a concrete 2027 deadline to buy against.

Details

A. AI Grid Current State and Enterprise-Readiness Gaps

The baseline below comes from prior context. Validate it against the attached documents.

Area	Current state	Enterprise-grade gap
Lineage	Began as an extension of an existing vulnerability-operations platform into AI attack surface management; now repositioned as standalone	Remove all dependencies on the parent platform (auth, tenancy, CVE pipelines, UI shell); make AI Grid its own brand and codebase
Data model	AI-native schema alongside CVE tables; `ai_asset_findings` as a parallel findings domain behind a preserved FindingService boundary; PostgreSQL + JSONB for graph v1	Formal versioned ontology for 8 artifact families; graph query performance at 100k+ nodes; migration path to a graph-native store or graph layer if JSONB traversal limits are hit
Discovery	GitHub static discovery live; Azure discovery built but kill-switched; 6-plane discovery strip shown in demo	Production connectors for AWS (Bedrock/AgentCore/SageMaker), Azure (AI Foundry/OpenAI, Copilot Studio), GCP (Vertex/Gemini Enterprise), M365, SaaS agent platforms, MCP servers and IDE agent configs, model hubs
Assessment	Misconfig → Vuln → Behavioral sequencing; ModelScan for model serialization/weight scanning; behavioral testing is Tier 3/phase-dependent	Misconfig and supply-chain checks mapped to OWASP/ATLAS; behavioral testing kept out of Year 1 production scoring
Scoring	Conservative exposure standard (probabilistic/runtime signals must not weaken exposure scoring)	Documented, explainable scoring model; separate "confidence" and "behavioral risk" channels; customer-tunable weights with audit
UI	Overview, Agents, Data Access, Remediation, AI Inventory, CISO Framework views — several are demo mocks	Replace mocks with live data; role-based views for CISO, AI Security Engineer, Platform/AppSec, Risk/Compliance
Integrations	SOC pipeline, ML-BOM export and delegated-authority chain tracing identified as phase-dependent	SIEM (Splunk, Sentinel, Chronicle), ITSM (ServiceNow, Jira), GRC, IdP (Entra, Okta), CNAPP/DSPM ingestion; public REST/GraphQL API; webhooks; CycloneDX ML-BOM export
Platform	Prototype deployment	Multi-tenancy with hard isolation, SSO (SAML/OIDC), SCIM, RBAC/ABAC, immutable audit log, encryption with customer-managed

Area	Current state	Enterprise-grade gap
		keys, data residency (EU/US/UK), single-tenant SaaS and customer VPC options, SLOs, DR
Assurance	None	SOC 2 Type I → Type II, ISO 27001, pen test, SBOM of AI Grid itself, then ISO/IEC 42001 for AI Grid's own AI features

Standing principles carried forward as design constraints:

- discovery gates everything (inventory → classification → assessment → enforcement);
- no force-fitting AI artifacts into CVE paradigms;
- the conservative exposure standard;
- runtime agent governance is treated as a categorically different problem from static configuration assessment.

B. Generalised Enterprise AI Direction → Challenge → AI Grid Capability

This synthesis draws on the Enterprise AI strategy reference (attached), generalised, plus industry data.

Enterprise AI ambition (generalised)	Security/governance challenge created	AI Grid capability
Scale from pilots to hundreds of production AI use cases	No authoritative inventory; ownership unclear; AI Act classification impossible without inventory	Continuous multi-plane discovery; AI asset register with owner, purpose, risk tier
Enterprise-wide copilots and assistants	Oversharing of sensitive data through retrieval; permission sprawl	Data Access view: assistant → connector → data-store reachability; DSPM ingestion rather than rebuilt DSPM
Agentic and multi-agent workflows	Agents act with delegated authority; tool misuse, goal hijack, cascading failures (OWASP ASI01–ASI10)	Agent inventory, tool/MCP graph, delegated-authority chain tracing (Year 2), runtime telemetry (Year 2–3)
Central AI platform / model gateway	Gateway covers sanctioned traffic only; blind to direct SaaS and developer paths	Treat gateways as a telemetry source; flag AI assets that bypass the gateway
Mix of proprietary, open-weight and third-party models	Malicious or serialized-payload models; unsigned artifacts; licensing	ModelScan, OpenSSF model-signing verification, CycloneDX ML-BOM
AI-assisted software development	IDE agents and MCP configs as new RCE surface (e.g., CVE-2026-30615 zero-click in Windsurf) OX Security	Code/IDE plane discovery of agent configs, MCP server allowlist drift, secrets in agent config
Embedded third-party/SaaS AI	Vendor AI features enabled silently; supply-chain risk	SaaS AI connector coverage; third-party AI register for procurement and TPRM
Shadow AI	Rising breach share and cost	Ingest from SSE/CASB/browser tools (partner) rather than building usage control
Operating model: AI CoE, federated delivery, model risk management	Fragmented ownership; model risk teams need evidence	Persona-specific workflows; evidence packs; control-to-framework mapping

Enterprise AI ambition (generalised)	Security/governance challenge created	AI Grid capability
Responsible AI and regulatory obligations (regulated enterprises)	EU AI Act, DORA/NIS2 ICT risk, sector model-risk expectations, Singapore agentic guidance	Framework mapping engine; audit-ready exports; Annex III classification support
Workforce enablement at scale	More builders and more low-code agents	Low-code agent platform coverage (Copilot Studio, Agentforce)

C. AI Security Industry Direction (2025–2026, outlook to 2030)

Market framing.

- Gartner's AI Security Platform (AISP) concept has two pillars: AI usage control and AI application security. Gartner predicts over 50% of enterprises will use AISPs by 2028, up from under 10% in 2025, Cato Networks and expects unified platforms to dominate over point products. Security Boulevard
- Gartner also published a February 2026 Market Guide for Guardian Agents and named Zenity the "company to beat" in AI agent governance (April 2026). Tracxn Beri
- **Reading:** buyers will consolidate. A standalone product survives by being the neutral system of record that platforms plug into, or by being deep enough to be acquired on its own terms.

Consolidation signals.

Acquirer → target	Status	Signal
Google → Wiz	Closed March 11, 2026 ($32B) Feinternational Softwarestrategiesblog	CNAPP incumbents absorb AI-SPM; Wiz now covers AgentCore, Copilot Studio, Agentforce
Palo Alto Networks → CyberArk	Closed February 2026 (~$25B) Feinternational	Identity for human, machine and AI-agent access becomes a platform pillar Feinternational
Palo Alto Networks → Protect AI	Closed 2025 (widely reported ~$500M) Softwarestrategiesblog	Model supply-chain scanning folded into Prisma AIRS
ServiceNow → Veza, Armis	Veza closed March 2, 2026; Armis closed April 2026 Feinternational	Governance hub adds access graph and asset intelligence to AI Control Tower
Check Point → Lakera	Closed October 22, 2025 (~$201.8M per SEC 20-F)	Runtime guardrails and red teaming absorbed by network security
SentinelOne → Prompt Security; Zscaler → SPLX; CrowdStrike → Pangea; Cato → Aim; F5 → CalypsoAI; Tenable → Apex	Closed 2025–early 2026 Softwarestrategiesblog	Every major security platform now owns an AI runtime/guardrail capability
Proofpoint → Acuvity; Cisco → Astrix, Galileo; Akamai → LayerX; 1Password → Apono; A10 → TrojAI	2026	Second wave: NHI/agent identity, usage control, red teaming

Snyk–Invariant Labs is listed as a candidate acquisition but was not independently verified in this research; treat it as unconfirmed.

Competitive map and where to play.

Segment	Leaders (Sept 2026)	AI Grid stance
Cross-platform AI-SPM / agent discovery	Noma, Zenity, Wiz AI-APP, Orca, Tenable AI Exposure, Straiker Discover AI	**Compete head-on — core wedge**; differentiate on exposure graph, conservative scoring and evidence
Runtime guardrails / AI firewalls / gateways	Palo Alto Prisma AIRS, Cisco AI Defense, F5, Check Point, cloud-native (Bedrock Guardrails, Model Armor)	**Integrate** — ingest verdicts and telemetry, never build
AI usage control / browser / shadow AI	Akamai-LayerX, Harmonic, Zscaler, Netskope, SentinelOne-Prompt	**Integrate** as discovery source
Agent identity / NHI	Microsoft Entra Agent ID, Okta, CyberArk (PANW), Cisco-Astrix, Aembit, Veza (ServiceNow)	**Integrate** — build the delegated-authority graph on their data
AI governance hubs	ServiceNow AI Control Tower, Credo AI, Holistic AI, OneTrust	**Partner** — push evidence and findings in; do not become a GRC tool
AI red teaming / assurance	Mindgard, HiddenLayer, Straiker, Zscaler-SPLX, Promptfoo	**Partner in Year 1, build targeted agent assurance in Year 2–3**
Model supply chain	Protect AI (PANW), HiddenLayer, JFrog	**Build lightweight** (ModelScan + signing verification + ML-BOM)

White space for a standalone product:

- Neutrality across Microsoft, Google, AWS and ServiceNow estates. Regulated enterprises are multi-cloud and wary of letting one platform vendor grade its own agents.
- A causal exposure graph (agent → identity → tool/MCP → data → blast radius) that is explainable to a board.
- Regulator-grade evidence tied to control frameworks.
- Coverage of the developer plane (IDE agents, MCP configurations), where platform tools are weakest and CVE activity is highest.

Standards trajectory to build against.

- **OWASP Top 10 for Agentic Applications 2026** (published December 9, 2025): ten categories, ASI01 Agent Goal Hijack through ASI10 Rogue Agents, plus the OWASP LLM Top 10 2026 and MCP Top 10. (Cycode +2)
- **MITRE ATLAS:** v5.1.0 (November 2025) lists 16 tactics and 84 techniques. 2026 updates added MCP case studies and agent techniques such as AML.T0104 Publish

Poisoned AI Agent Tool. (Vectra AI)

- **NIST:**
  - Cyber AI Profile preliminary draft (IR 8596, December 16, 2025). (Global Policy Watch) (Lab Space)
  - COSAiS SP 800-53 overlays, with an annotated predictive-AI outline in January 2026 and generative and agentic use cases planned. (Crowell & Moring) (nist)
  - An RFI on AI agent security (January 2026). (arxiv) (Pillsbury Winthrop S...)
  - The CAISI AI Agent Standards Initiative (February 17, 2026). (Zylos)
  - The NCCoE concept paper "Accelerating the Adoption of Software and AI Agent Identity and Authorization" (February 5, 2026; comments closed April 2, 2026; no project description yet). (Lab Space) (nist)
- **ETSI EN 304 223:** 13 principles across secure design, development, deployment, maintenance and end of life. (Rescana)
- **ISO/IEC 42001** for AI management systems. AI Grid's own AI features should target it in Year 2.
- **Agent protocols:**
  - MCP 2026-07-28 made the protocol stateless, deprecated Dynamic Client Registration in favour of Client ID Metadata Documents, and added RFC 9207 issuer validation. (Gupta Deepak)
  - The MCP Enterprise-Managed Authorization extension was declared stable on June 18, 2026. It is built on the IETF ID-JAG draft (Cross-App Access). (modelcontextprotocol) (ietf)
  - A2A is governed by the Linux Foundation and released its first stable specification, v1.0, in 2026, with over 150 supporting organisations. (Linux Foundation) (HPCwire)
- **Agent identity:**
  - IETF `draft-ietf-wimse-aims-00` (AI Identity Management System, WIMSE working group, September 15, 2026). It states agents "MUST be assigned exactly one WIMSE identifier, which MAY be a SPIFFE ID". (ietf)
  - The earlier individual OAuth on-behalf-of-for-agents draft has expired. (IETF)
  - The OpenID Foundation whitepaper "Identity Management for Agentic AI" (October 2025). (OpenID) (OpenID)

Threat landscape.

- OX Security's April 15, 2026 advisory documented systemic MCP STDIO command injection across 10 CVEs. Examples: CVE-2026-30615 (Windsurf zero-click RCE via prompt injection into MCP config) and CVE-2026-40933 (Flowise, CVSS 10.0). (PolicyLayer +2)
- Other disclosures:

    - CVE-2025-6514 (mcp-remote, CVSS 9.6); arxiv Practical DevSecOps
    - CVE-2026-0755 (gemini-mcp-tool, CVSS 9.8); AuthZed
    - CVE-2026-13341 (confused-deputy indirect prompt injection in a vendor MCP server); arxiv
    - Zenity's AgentForger disclosure against hosted workspace agents (July 2026); Tracxn
    - trojanised MCP servers distributed via public registries. AuthZed
- Mandiant's M-Trends 2026 draws on more than 500,000 incident-response hours. It reports that the median time from initial access to handoff to a secondary threat group fell from more than 8 hours in 2022 to 22 seconds in 2025. Detection-only products are losing relevance; remediation workflows matter.

Regulation (generalised).

- EU AI Act GPAI obligations have applied since August 2025. Article 50(2) watermarking applies from December 2, 2026. Annex III high-risk obligations apply from December 2, 2027, and Annex I from August 2, 2028. Usercentrics VerifyWise
- DORA and NIS2 bring AI supply chains into ICT third-party risk for regulated enterprises.
- Singapore's IMDA Model AI Governance Framework for Agentic AI (January 22, 2026; v1.5 May 2026) is organised around four dimensions and calls for agent identity and audit trails. Baker McKenzie arxiv
- Colorado SB 26-189 (effective January 1, 2027) narrows the state regime to automated-decision disclosure. Hunton SecureW2
- **Tooling implication:** inventory, classification, human-oversight evidence and audit trails are required everywhere. Prescriptive technical controls are not.

Buyer expectations in 2026:

- deployment choice (multi-tenant SaaS, single-tenant, customer VPC);
- no customer prompt or data content leaving the tenant by default;
- SOC 2 Type II as table stakes, ISO 27001 for EU and UK buyers, and ISO/IEC 42001 increasingly asked of AI vendors;
- SSO/SCIM;
- integrations with SIEM, SOAR, ITSM, GRC, IdP and CNAPP;
- API-first design;
- time to first value in days;
- pricing that does not scale per employee.

Microsoft's per-user Agent 365 licensing creates an opening for per-asset pricing. Microsoft Learn

D. Positioning, ICP and Go-to-Market

- **Positioning thesis:** "The independent AI exposure graph for the enterprise: every model, agent, tool and identity, what each can reach, and proof that it is governed."
- **ICP / beachhead:** regulated enterprises (financial services, insurance, healthcare, critical infrastructure) with 5,000+ employees. They are multi-cloud, have a central AI platform plus federated builders, and face 2027 EU AI Act or sector model-risk deadlines.
    - Economic buyer: the CISO.
    - Co-sponsors: Head of AI Platform and Model Risk / Compliance.
- **Wedge:** discovery and AI inventory plus exposure management across code, cloud and SaaS agent platforms.
- **Expansion path:** evidence and compliance → agent identity and delegated authority → runtime governance → continuous assurance.
- **Build vs partner vs integrate:**
    - Build: discovery, graph, scoring, evidence, agent assurance.
    - Integrate: guardrails, gateways, IdPs, DSPM, CNAPP, SSE.
    - Partner: GRC hubs and red-teaming services.
- **Pricing and packaging:**
    - Platform fee plus tiers by AI assets or agents under management.
    - Modules: Discover, Expose, Evidence (Year 1); Govern, Assure (Years 2–3).
    - A single-tenant or VPC deployment uplift.
    - Design partners get discounted multi-year terms in return for referenceability and roadmap input.
- **GTM motion:**
    - Founder-led design-partner sales (Year 1).
    - A repeatable enterprise motion with solutions engineers and cloud marketplace listings on AWS, Azure and GCP (Year 2).
    - Channel partnerships with SIs and MSSPs for regulated enterprises (Years 2–3).

E. Capacity and Resourcing Assumptions

Team size is unknown. The plan assumes:

- **Year 1:** 10–14 FTE, of which 7–9 are engineers (2 platform/SRE, 3 connectors/discovery, 2 graph/scoring, 1 frontend, 1 security engineer), plus 1 PM, 1 designer, 1–2 solutions engineers, and fractional compliance.
- **Year 2:** 25–30 FTE.
- **Year 3:** 40–55 FTE.

If Year 1 capacity is below 8 engineers, cut Phase 1.3 scope (drop GCP and SaaS agent platforms) before cutting enterprise-grade platform work. A first customer will not go to production without the latter.

1-Year Strategy (Q4 2026 – Q3 2027): From Demo to First Production Enterprise Customer

Objective: convert demos into 1–3 production design partners and make AI Grid pass enterprise procurement and security review without exceptions.

Phase 1.1 — Demo to Design Partner (Oct–Dec 2026)

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
1.1a	Standalone extraction	Separate AI Grid from the parent vulnerability platform: own auth, tenancy, deploy pipeline, brand. Required by standalone positioning	None	All	Zero runtime dependency on parent services (verified by dependency scan); independent CI/CD; clean install from scratch in under 60 minutes
1.1b	Demo-mock retirement	Replace mocked Overview, Agents, Data Access, Remediation and CISO Framework data with live pipeline output, or hide the view	1.1a	CISO, AI Sec Eng	100% of shipped views backed by live data; mock views behind a feature flag; demo script runs on a real tenant
1.1c	GitHub discovery hardening	Production-grade GitHub/GitHub Enterprise discovery of AI artifacts, agent configs, MCP configs, model files, prompt templates	1.1a	AppSec / Platform Eng	Scans 5,000 repos in under 4 hours; artifact-family precision ⩾95% and recall ⩾90% on a labelled benchmark of 500 repos; incremental rescan on push
1.1d	Azure discovery re-enablement	Lift the kill switch with a least-privilege, read-only connector for Azure AI Foundry/OpenAI and Copilot Studio	1.1a, security review	AI Sec Eng	Read-only permissions documented; kill switch retained as per-tenant control; tested on 3 subscriptions with more than 200 AI resources; zero write calls in audit
1.1e	Design-partner program	Signed design-partner agreements with success criteria, data-	1.1b	CISO	At least 2 signed design-partner agreements, each with written success

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
		handling terms and a pilot plan			criteria and an executive sponsor
1.1f	Product security baseline	Threat model of AI Grid itself, secrets management, SAST/SCA in CI, external pen test booked	1.1a	Buyer security review	Threat model reviewed; no critical/high SAST or SCA findings open for more than 14 days; pen test scheduled; SBOM produced per release

Phase exit criteria:

- two design partners live on real data;
- a GitHub-plus-Azure inventory produced for each;
- a security questionnaire (SIG Lite or CAIQ) completed with no "No" answers on critical controls.

Phase 1.2 — First Production Customer (Jan–Mar 2027)

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
1.2a	Enterprise identity and access	SSO (SAML 2.0/OIDC), SCIM 2.0, RBAC with 4 persona roles plus custom roles, session policy	1.1a	All	Tested with Entra ID and Okta; SCIM deprovisioning takes effect within 5 minutes; every API endpoint authorisation-tested in CI
1.2b	Immutable audit log	Every user, API and connector action logged and exportable	1.2a	Risk/Compliance	100% of state-changing actions logged; tamper-evident (hash chain); retention configurable to 7 years; SIEM export
1.2c	Deployment models v1	Multi-tenant SaaS with hard isolation plus single-tenant SaaS; EU and US regions	1.1a	Procurement	Tenant isolation pen-tested; per-tenant encryption keys; data residency attested; restore from backup takes under 4 hours (RTO) with under 1 hour of data loss (RPO), tested
1.2d	AWS discovery	Bedrock, Bedrock AgentCore, SageMaker,	1.1a	AI Sec Eng	Read-only IAM policy

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
		Lambda-hosted agents, IAM role mapping			published; tested on 3 accounts with more than 300 AI resources; asset-to-IAM-role linkage ≥95%
1.2e	Exposure graph v1	Agent/app → identity → tool/MCP → data-store edges in PostgreSQL + JSONB; explainable exposure score under the conservative standard	1.1c, 1.1d, 1.2d	CISO, AI Sec Eng	Graph handles 50k nodes / 250k edges with p95 query under 2 seconds; every score has a human-readable path explanation; zero probabilistic inputs in the exposure score (unit-tested)
1.2f	Findings and remediation workflow	`ai_asset_findings` lifecycle; Jira and ServiceNow ticketing; owner assignment	1.2e	Platform/AppSec	Bidirectional ticket sync; SLA tracking; mean time from finding to ticket under 5 minutes
1.2g	First production go-live	Convert at least one design partner to a paid production contract	1.2a–f	CISO	Signed paid contract; passed the customer's third-party security review; in production for 30 days with

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
					no Sev-1; customer-confirmed success criteria met

Phase exit criteria:

- at least one paying production customer;
- SOC 2 Type I report issued;
- external pen test with no open critical or high findings.

Phase 1.3 — Enterprise-Grade Platform (Apr–Jun 2027)

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
1.3a	Coverage expansion	GCP (Vertex AI, Gemini Enterprise Agent Platform), M365/Copilot agents, Salesforce Agentforce, Databricks; MCP server and IDE agent configuration discovery on endpoints via MDM/EDR partner feeds	1.2e	AI Sec Eng	6 discovery planes live; each connector has a published permission manifest, a test suite and a coverage matrix; MCP config drift detected within 24 hours
1.3b	Model supply-chain assurance	ModelScan for serialization/weights; OpenSSF model-signing (Sigstore) verification; model hub provenance	1.1c	AI Sec Eng	Detects 100% of a known-malicious model corpus (pickle/unsafe deserialization test set); signature-verification status shown per model; false-positive rate under 5% on benign corpus
1.3c	Framework mapping and evidence pack v1	Map findings and controls to OWASP LLM and Agentic Top 10, MITRE ATLAS, NIST AI RMF / 600-1, ISO/IEC 42001 Annex A, EU AI Act articles, ETSI EN 304 223	1.2e	Risk/Compliance	Every finding type mapped to at least one framework; one-click evidence export (PDF + JSON); reviewed by one external auditor or

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
					design-partner compliance lead
1.3d	AI asset register and classification	Owner, purpose, data categories, autonomy level, EU AI Act risk-tier suggestion (human-confirmed)	1.3a	Risk/Compliance, CISO	90% of discovered assets have an owner within 30 days at the customer; classification changes audited; export to GRC
1.3e	Integrations v1	Splunk, Microsoft Sentinel, Google SecOps; ServiceNow GRC/AI Control Tower; Entra ID and Okta read; webhook plus public REST API with OpenAPI spec	1.2b, 1.2f	SOC, Platform Eng	5 integrations certified; API coverage of 100% of UI functions; rate-limited, versioned, documented
1.3f	Reliability and scale	SLOs, observability, horizontal scaling of scanners	1.2c	Procurement	99.9% monthly availability SLO met for 60 days; supports 500k assets per tenant in load test; runbooks and on-call in place

Phase exit criteria:

- two production customers;
- the SOC 2 Type II observation window underway;
- evidence pack accepted by at least one customer's audit or model-risk function.

Phase 1.4 — Repeatability (Jul–Sep 2027)

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
1.4a	Customer-VPC deployment	Helm/Terraform deployable into customer AWS/Azure for regulated buyers	1.2c, 1.3f	Procurement	Installed in 2 customer-controlled environments in under 1 day each; no outbound data except opt-in telemetry; upgrade path tested
1.4b	Agent inventory v2 and delegated-authority preview	Ingest Entra Agent ID, Okta and cloud IAM agent identities; map OBO vs autonomous access; MCP OAuth/EMA configuration checks	1.3a, 1.3e	AI Sec Eng, IAM	Agent identities reconciled to discovered agents at ≥90% match; flags token passthrough, over-scoped consent and missing issuer validation per MCP 2026-07-28
1.4c	ML-BOM export	CycloneDX ML-BOM (and SPDX 3.0 AI profile) per AI system	1.3b, 1.3d	Risk/Compliance, Platform	Schema-validated output; generated for 100% of registered AI systems; ingestible by at least one customer SBOM tool
1.4d	Time-to-value onboarding	Guided setup, connector health checks, first-inventory report	1.3a	CISO	First inventory within 48 hours of contract for SaaS tenants;

#	Roadmap item	Scope and rationale	Dependencies	Persona / JTBD	Definition of Done
					onboarding completed without engineering involvement in 3 of the last 4 deployments
1.4e	Certifications	SOC 2 Type II issued; ISO 27001 Stage 1	1.2c	Procurement	Reports issued; trust centre published

Year 1 success metrics:

- **Product:** 6 discovery planes, 5+ integrations, exposure graph at 500k assets per tenant.
- **Customer:** at least 3 production customers, at least 2 referenceable, and 90-day logo retention of 100%.
- **Business:** ARR target set by leadership (placeholder: an ARR level that supports a Series A/B raise), sales cycle under 6 months for design-partner conversions, gross margin above 70% on SaaS tenants.

3-Year Strategy (Q4 2026 – Q3 2029): From Visibility to Governed Autonomy

Where enterprise AI will be in years 3–5. Gartner forecasts agentic AI spend overtaking chatbot spend by 2027. Softwarestrategiesbl... Enterprises will run fleets of agents with delegated authority, chained across MCP and A2A, some acting autonomously without a human in session. The security problem shifts from "what exists and how is it configured" to "what is this agent doing right now, on whose authority, and can we stop it." AI Grid must earn the right to that runtime layer on top of the Year 1 graph, without breaking the conservative exposure standard.

Year 1 Recap (Q4 2026 – Q3 2027)

Standalone, enterprise-grade discovery, exposure graph and evidence platform. At least 3 production customers. SOC 2 Type II.

Year 2 (Q4 2027 – Q3 2028): Agent Identity, Runtime Telemetry and Governance

#	Roadmap item	Scope and rationale	Dependencies	Definition of Done
2.1	Delegated-authority chain tracing (GA)	Full human → agent → sub-agent → tool → resource chains, using IdP data, OAuth token-exchange/ID-JAG metadata and WIMSE/SPIFFE identifiers where present	1.4b	End-to-end chains resolved for ≥85% of agent actions in 2 customer estates; standards adapters abstract draft specs so a spec change needs under 2 weeks of work
2.2	Runtime telemetry ingestion	Ingest from gateways/guardrails (Prisma AIRS, Cisco AI Defense, F5, Model Armor, Bedrock Guardrails), agent frameworks via OpenTelemetry GenAI conventions, MCP gateways	1.3e	5 telemetry sources; 10k events/second per tenant sustained; telemetry stored in a separate "behavioural" channel that never modifies the exposure score (enforced by tests)
2.3	Behavioural baselines v1 (open research question)	Per-agent baselines of tool usage, data access and destinations; anomaly alerts to SIEM	2.2	Precision ≥80% on alerts over a 60-day design-partner evaluation; every alert carries evidence and a confidence score; analyst feedback loop live
2.4	Policy-as-code and partner enforcement	Declarative policies (e.g., "no autonomous agent with write access to payment systems without human approval"), enforced through IdP conditional access, gateways and ticket gates, not an AI Grid inline proxy	2.1	Policies evaluated continuously; enforcement actions via at least 3 partner APIs; every action reversible and audited; dry-run mode default
2.5	Agent assurance testing v1	Pre-deployment and scheduled tests for OWASP ASI risks (goal hijack, tool misuse, memory poisoning, indirect prompt	1.3c	Test library covering all 10 ASI categories; results feed findings but tagged "assurance", not

#	Roadmap item	Scope and rationale	Dependencies	Definition of Done
		injection via tool outputs) against sandboxed agents		exposure; reproducible runs
2.6	Memory and context security checks (open research question)	Inventory of agent memory stores and RAG corpora; poisoning indicators; cross-tenant/context boundary checks	2.2	Memory stores discovered for the 3 top agent frameworks; boundary-violation detection validated on seeded test cases
2.7	Compliance readiness for Dec 2027	EU AI Act Annex III workflow: classification, human-oversight evidence, logging retention; DORA/NIS2 ICT third-party AI register	1.3c, 1.3d	At least 2 customers use AI Grid evidence in a regulator or internal audit submission before December 2, 2027
2.8	Platform scale and assurance	Evaluate graph-native layer; ISO 27001 certified; ISO/IEC 42001 for AI Grid's own AI features; FedRAMP/IRAP go/no-go decision	1.3f	2M assets per tenant at p95 under 3 seconds; certifications issued
2.9	GTM scale	Cloud marketplaces; SI/MSSP partners; first non-financial regulated vertical	1.4d	10–15 production customers; net revenue retention above 120%; 2 channel-sourced deals

Year 2 exit criteria:

- delegated-authority tracing and runtime telemetry in production at 3 or more customers;
- zero exposure-score regressions caused by probabilistic signals;
- Annex III evidence used in real audits.

Year 3 (Q4 2028 – Q3 2029): Continuous Assurance for Multi-Agent Estates

#	Roadmap item	Scope and rationale	Dependencies	Definition of Done
3.1	Multi-agent / A2A governance	Discover and graph A2A agent cards, inter-agent delegation, cascading-failure paths (ASI07/ASI08)	2.1, 2.2	A2A interactions mapped in 2 customer estates; cascading blast-radius simulation validated against a tabletop exercise
3.2	Runtime response orchestration	Human-approved and pre-authorised response actions (revoke token, quarantine agent, disable MCP server) via IdP, gateway and platform APIs	2.4	Median time from detection to containment under 5 minutes for pre-authorised playbooks; 100% of actions audited and reversible
3.3	Continuous agent assurance	Assurance tests triggered on agent, model, tool or prompt change; regression gates in CI/CD	2.5	Assurance gate adopted in the pipelines of 5 customers; mean time to detect a regression under 24 hours
3.4	Guardian-agent capability (bounded)	AI Grid's own triage/investigation agent under its own least-agency controls and 42001 governance	2.8	Reduces analyst triage time by at least 40% in measured trials; zero autonomous enforcement without policy pre-authorisation
3.5	Benchmark and research leadership	Publish an annual AI exposure benchmark; contribute to OWASP, ATLAS, CoSAI, NIST COSAiS agentic overlays	Ongoing	At least 2 accepted contributions to standards bodies; benchmark cited by at least one analyst firm
3.6	Ecosystem and data network	Partner SDK for third-party connectors; bidirectional integrations with AI governance hubs	1.3e	20+ connectors with 5 or more partner-built; certified partner program

Year 3 success metrics:

- 30–50 production customers;

- recognised in the analyst categories for AI security platforms and agent governance;
- net revenue retention above 125%;
- a decision point reached: independent growth path versus a strategic transaction on favourable terms.

Key Risks and Mitigations

Risk	Likelihood	Mitigation
Platform bundling (Microsoft Agent 365, Wiz AI-APP, ServiceNow AI Control Tower) makes "good enough" free	High	Win on neutrality and cross-estate graph; integrate with them as data sources; sell to multi-platform regulated enterprises
Well-funded independents (Noma, Zenity, HiddenLayer) outspend	High	Narrow beachhead (regulated enterprises, exposure plus evidence); depth over breadth; conservative, explainable scoring as trust differentiator
Draft agent-identity standards change	Medium	Adapter layer; track IETF WIMSE AIMS, MCP EMA and NIST NCCoE; no hard dependency on any draft
First customer slips	Medium	Run 2–3 design partners in parallel; keep Phase 1.2 enterprise-basics scope fixed
Behavioural detection false positives erode trust	Medium	Separate channels; opt-in alerting; precision gates before GA
AI Grid itself becomes an attack target (holds a map of the entire AI estate)	Medium	Read-only connectors, per-tenant keys, customer-VPC option, continuous pen testing, bug bounty by Year 2

Key Decision Points and Assumptions

- **Q1 2027:** confirm whether PostgreSQL + JSONB supports the Year 2 graph, or schedule a graph-layer migration.
- **Q3 2027:** decide whether to build a lightweight MCP gateway. Default: no. Integrate unless design partners block on it.
- **Q2 2028:** FedRAMP/public-sector go/no-go.
- **Q3 2029:** capital strategy decision (independent scale vs strategic transaction).
- **Assumptions:**
  - the regulatory calendar holds;
  - enterprises stay multi-platform;

- customers accept read-only discovery connectors;
- team capacity matches Section E.

Caveats

- The attached AI Grid documents and the enterprise strategy PDF could not be read in this session. Validate the current-state table and the ambition-to-capability mapping against them before committing dates.
- Market figures are forecasts, not measured spend. The IBM 2026 breach statistics come from IBM's 2026 Cost of a Data Breach Report (IBM/Ponemon, July 29, 2026), but outlets differ on the denominator for the 43% shadow-AI figure. Noma's ARR growth and customer counts are vendor-reported. AppSec Santa
- Some acquisition values are press estimates; the Protect AI deal value is reported, not disclosed. Softwarestrategiesbl... Snyk–Invariant Labs was not verified.
- Agent-identity standards (IETF AIMS, ID-JAG, NIST NCCoE) are still drafts or concept papers and may change materially. nist +2
- ARR and headcount figures are planning placeholders, not forecasts.